

NORTHWIND TECHNOLOGIES

INFORMATION SECURITY POLICY

Document No.: NT-IT-SEC-014

Version: 2.0

Effective Date: 15 March 2026

Owner: Information Security Office

Classification: Internal — Confidential

Table of Contents

1. Objective

This policy defines how Northwind Technologies protects the confidentiality, integrity, and availability of its information assets. It establishes mandatory controls for employees, contractors, and third parties who access Company systems or data.

The policy is built around an information security management approach aligned with ISO/IEC 27001 principles and is enforced by the Information Security Office (ISO).

2. Information Classification

All information must be classified so that handling controls can be applied consistently. The four classification levels are defined below.

Level	Description	Example
Public	Approved for external release.	Marketing brochures
Internal	For employees and authorized parties.	Org charts, processes
Confidential	Restricted; limited need-to-know.	Contracts, salaries
Restricted	Highest sensitivity; strict controls.	Encryption keys, PII

3. Access Control

3.1 Principle of Least Privilege

Access rights are granted on a least-privilege, need-to-know basis. Privileges are reviewed quarterly and revoked promptly when no longer required or upon termination.

3.2 Authentication

- Multi-factor authentication is mandatory for all remote access and privileged accounts.
- Shared accounts are prohibited unless formally approved and logged by the ISO.
- Service accounts must have credentials rotated at least every 90 days.

4. Encryption Standards

Cryptographic controls protect data in transit and at rest. The minimum approved standards are listed below.

Context	Minimum Standard
Data at rest	AES-256
Data in transit	TLS 1.2 or higher
Disk encryption	Full-disk on all endpoints
Key management	Hardware security module (HSM)

5. Incident Response

All suspected or confirmed security incidents must be reported to the Security Operations Center within one hour of discovery. The response process follows five phases.

1. Detection and reporting of the suspected incident.
2. Triage and severity classification by the on-call analyst.
3. Containment to limit the scope and impact.
4. Eradication of the root cause and recovery of affected systems.
5. Post-incident review and lessons-learned documentation.

Contact: soc@northwind.example | Security hotline: +1-555-0142 (24/7).

6. Endpoint and Device Security

- All endpoints must run approved anti-malware and receive automatic security patches.
- Lost or stolen devices must be reported within 24 hours for remote wipe.
- Removable media is blocked by default and permitted only by exception.
- Personal devices may access Company resources only through the approved MDM enrollment.

7. Third-Party and Vendor Security

Vendors handling Company data must undergo a security assessment before onboarding and sign a data processing agreement. High-risk vendors are reassessed annually.

- Due diligence questionnaires are required prior to contract signature.
- Vendor access is time-bound and monitored throughout the engagement.
- Sub-processors must be disclosed and approved in advance.

8. Compliance and Enforcement

Non-compliance with this policy may result in disciplinary action, suspension of system access, and, where applicable, legal consequences. Exceptions require written approval from the Chief Information Security Officer and are reviewed every six months.

Policy Owner	Information Security Office
Approved By	Chief Information Security Officer
Review Cycle	Annual